Hawassa University

Institute of Technology

Faculty of Informatics

Department of Computer Science

Research Proposal

Enhancing Web Application Security Using AI-Based Threat Detection Systems

---

Course: Research Methods in Computer Science (CoSc3101)

Student Name: Abay Shemelis

ID Number: 1003/16

Section: 3

Instructor: Birane.B

Submission Date: May 1, 2026

Contents

1 Abstract 2

2 Introduction 2

3 Problem Statement 3

3.1 Ideal Situation 3

3.2 Reality 3

3.3 Consequence 3

4 Objectives 3

4.1 General Objective 3

4.2 Specific Objectives 3

5 Literature Review 4

6 Gap Analysis 4

6.1 Synthesis Matrix 5

7 Technical Methodology & Experimental Design 5

7.1 System Architecture and Functional Flow 5

7.1.1 System Components 6

7.1.2 Functional Flow 7

7.1.3 Operational Performance 7

7.2 Tool Justification 7

7.3 Data Strategy 7

7.4 Evaluation Metrics 8

7.5 Implementation Timeline (Gantt Chart) 9

7.6 Ethical Considerations 9

8 Version Control 10

9 Standard Workflow 11

1 Abstract

Traditional signature-based Web Application Firewalls (WAFs) fail to detect zero-day and polymorphic web attacks, while existing AI solutions lack explainability and real-time performance. This research proposes a hybrid CNN-LSTM architecture with out-of-band SHAP-based Explainable AI (XAI) to detect SQLi and XSS attacks. The system will preprocess HTTP traffic using Byte Pair Encoding (BPE) and classify requests with sub-60ms latency. Using the SR-BH 2020 dataset from IEEE DataPort, the model will be evaluated on Accuracy, F1-Score, and False Positive Rate (target $<1\%$). The expected outcome is a transparent, low-latency detection framework achieving F1-Score $\geq 95\%$.

Keywords: Web Security, CNN-LSTM, SHAP, XAI, Threat Detection

2 Introduction

The global digital ecosystem now depends on web applications for critical operations in commerce, healthcare, and education, making their security a non-negotiable prerequisite for organizational stability and user trust. However, as services rapidly digitize, traditional defensive perimeters based on static signatures have become fundamentally inadequate against the industrialization of attacker automation. Empirical studies show that mutated and obfuscated payloads can bypass commonly deployed rule-based platforms with evasion rates reaching as high as 79% [1], contributing to a global average data breach cost of $5.15 million in 2025 [2]. This research proposes a shift from reactive, deterministic filters to adaptive, AI-enhanced architectures that learn "normality" through behavioral analytics. By leveraging machine learning models that achieve detection rates between 94% and 99% while maintaining microsecond-level latency ($< 60\mu s$), this study aims to deliver a proactive security framework capable of neutralizing zero-day threats at the high speeds required for modern edge-native environments.

3 Problem Statement

3.1 Ideal Situation

Web applications should operate with zero successful attacks and perfect detection of malicious traffic in real time.

3.2 Reality

In 2025 alone, 48,185 Common Vulnerabilities and Exposures (CVEs) were published, a 20.6% increase from the previous year [3]. On average, 133 new vulnerabilities surface daily, with XSS and SQLi remaining most prevalent [4]. Current signature-based Web Application Firewalls (WAFs) fail to detect novel zero-day attacks, with 90 confirmed cases in 2025 [5]. Furthermore, modern AI-based solutions often operate as "black boxes," causing alert fatigue [6].

3.3 Consequence

The average cost of a data breach escalated to $4.88 million in 2024, causing significant financial loss and long-term reputational damage [7]. Organizations face increased operational costs and eroded user trust.

4 Objectives

4.1 General Objective

To develop a robust, explainable AI-enhanced detection framework that proactively identifies known and zero-day web vulnerabilities with high accuracy and minimal latency.

4.2 Specific Objectives

- To design a hybrid model combining CNN and LSTM architectures to achieve an F1-score $\geq 95\%$ on the SR-BH 2020 dataset by week 5.

- To integrate SHAP-based Explainable AI (XAI) to provide real-time interpretability, aiming to reduce analyst response time by 30%.
- To optimize inference architecture to ensure 90% of requests are processed within a 60-millisecond window.

5 Literature Review

Recent advances in web application security research indicate a clear paradigm shift toward the use of deep learning (DL) models for defending the semantic layer of modern systems. For instance, [8] demonstrated that Transformer-based architectures such as CodeBERT capture the contextual semantics of code for vulnerability detection tasks. In parallel, hybrid architectures combining Convolutional Neural Networks (CNNs) and Long Short-Term Memory (LSTM) networks have shown strong performance in modeling both spatial and temporal characteristics of network traffic, enabling improved detection of evolving attack behaviors [9]. Furthermore, the integration of explainability has emerged as a requirement for trust, as explored by [6] in the context of intrusion detection.

Despite these advancements, a critical limitation persists in the current state-of-the-art: most systems fail to simultaneously achieve high detection accuracy, real-time processing capability, and model interpretability. High-performing deep learning models often operate as opaque "black boxes," limiting their practical usability in security operations where explainability is essential for trust and rapid incident response. Additionally, the computational overhead of complex models introduces latency constraints, making them unsuitable for high-throughput, edge-native environments [10].

6 Gap Analysis

The reviewed literature reveals five critical gaps. First, [8] demonstrated high accuracy with CodeBERT-based vulnerability detection but incurred significant computational costs unsuitable for real-time edge deployment. Second, [11] achieved 99% accuracy using autoencoder-based feature extraction but demonstrated limited recall on minority

attack classes. Third, the CIC-IDS2017 dataset [12] is widely used but lacks modern web-specific attack vectors. Fourth, [9] achieved 99.3% accuracy with ML ensembles but did not address adversarial evasion risks. Fifth, [10] developed a real-time ML framework with adversarial training but lacked a prevention layer or explanation capability beyond the detection engine.

No existing system simultaneously achieves high detection accuracy, sub-60ms latency, and model interpretability. To address this gap, this research proposes a hybrid CNN-LSTM architecture with out-of-band SHAP-based explainability, balancing performance, speed, and transparency.

6.1 Synthesis Matrix

Table 1: Synthesis Matrix of Related Work

Author	Method	Dataset	Metric	Limitation
Fu et al. (2022) [8]	CodeBERT Transformer	Vulnerability datasets	High accuracy	High computational cost
Thalji et al. (2023) [11]	AE-Net + XGBoost	SQL queries	99% Acc.	Limited recall on minority classes
Sekyewa et al. (2023) [13]	Transformer + Ensemble	Web Logs	High accuracy	No latency study
Riverol et al. (2024) [9]	ML Ensemble	Web Data	99.3% Acc.	No adversarial robustness
Floris et al. (2025) [10]	ModSec-AdvLearn	Breach Logs	Real-time	No prevention/XAI layer

7 Technical Methodology & Experimental Design

7.1 System Architecture and Functional Flow

The overall system architecture of the proposed AI-enhanced web application security framework is illustrated in Fig. 1. The design will follow a sequential processing pipeline that balances high-speed threat detection with deep interpretability.

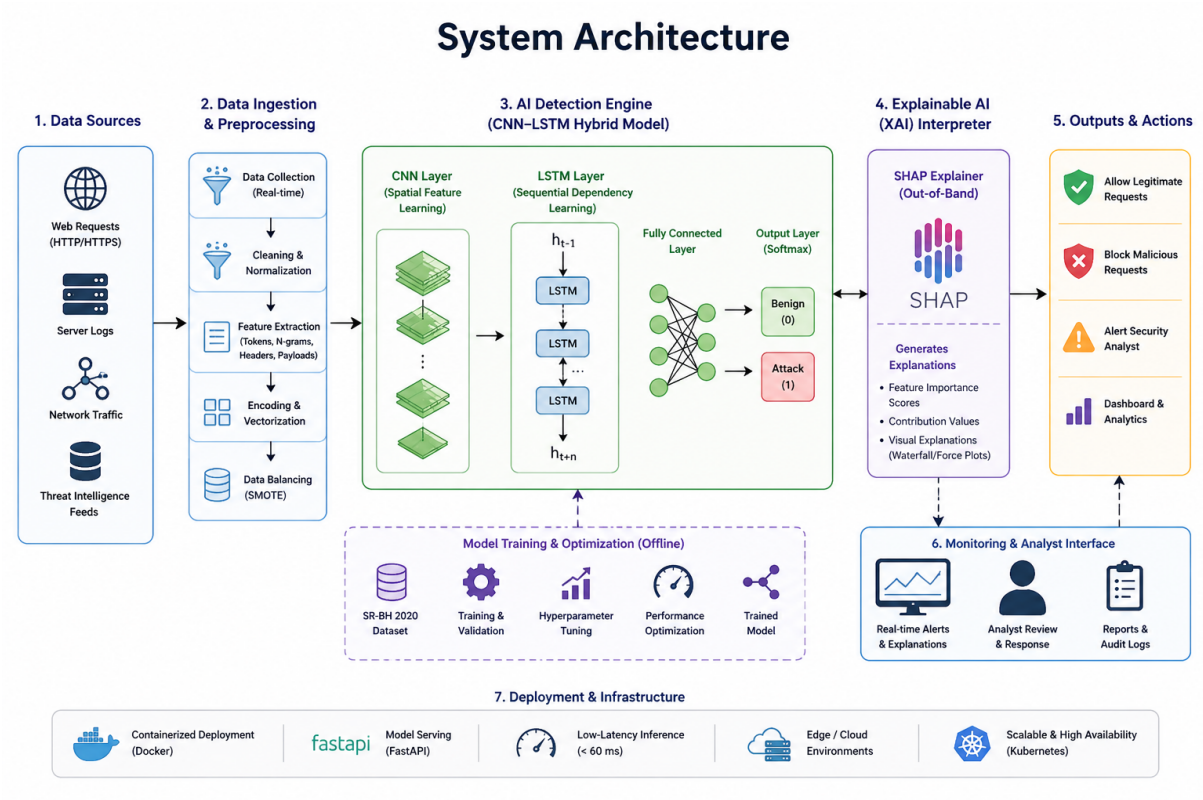

Figure 1: Proposed system architecture integrating data ingestion, preprocessing, a hybrid CNN-LSTM detection engine, and an out-of-band SHAP-based XAI module.

7.1.1 System Components

The framework will consist of four primary modules:

1. **Ingestion Layer:** This module will capture raw HTTP traffic via TAP/SPAN ports, ensuring zero impact on the primary network path and preserving system performance.

2. **Pre-processing Module:** This module will perform URL decoding, syntactic normalization, and tokenization using Byte Pair Encoding (BPE), transforming raw input into structured numerical tensors suitable for machine learning.

3. **AI Detection Engine:** This module will utilize a hybrid CNN-LSTM architecture, where the CNN will extract spatial features from request payloads and the LSTM will model temporal dependencies across sequential attack patterns.

4. **XAI Interpreter:** This module will apply SHAP (SHapley Additive exPlanations)

to compute feature attribution scores, enabling transparent and human-readable explanations for each detected threat.

7.1.2 Functional Flow

Data processing will begin at the ingestion layer, where traffic will be mirrored and forwarded to the preprocessing module for cleaning and normalization. The processed tensors will then be passed to the AI detection engine, which will classify requests as benign or malicious. Upon detection of a threat, the XAI interpreter will generate feature attribution scores, mapping the model's decision back to the original input to provide a clear and interpretable justification for the alert.

7.1.3 Operational Performance

To ensure suitability for real-time, high-traffic environments, detection latency (ΔT) will be defined as:

$$\Delta T = (T_{\text{pre-process}} + T_{\text{inference}} + T_{\text{XAI}}) < 60 \text{ ms} \tag{1}$$

This constraint will ensure that the system maintains both high detection accuracy and low-latency performance required for deployment in modern web infrastructures.

7.2 Tool Justification

PyTorch will be the primary framework due to its dynamic graph support, which is superior for rapid prototyping of custom attention mechanisms compared to TensorFlow. **Burp Suite** will be used to generate adversarial payloads to test model robustness.

7.3 Data Strategy

This study will utilize the SR-BH 2020 multi-label dataset from IEEE DataPort, which provides a comprehensive collection of real-world web traffic categorized by CAPEC attack patterns [14]. This dataset will be critical for addressing the modern "complexity crisis" in web security by providing high-fidelity logs for training.

To address the inherent class imbalance between benign traffic and specific malicious vectors - a common challenge in network intrusion detection - the Synthetic Minority Over-sampling Technique (SMOTE) will be applied. This method will generate synthetic samples for minority attack classes to prevent model bias and improve detection fairness [9].

Basic preprocessing steps, including syntactic normalization and Byte Pair Encoding (BPE), will be performed to convert raw HTTP payloads into structured numerical tensors suitable for the CNN-LSTM detection engine. This multi-step strategy will ensure improved data balance, higher model accuracy, and an enhanced capability to detect diverse, polymorphic attack types [10].

7.4 Evaluation Metrics

The performance of the AI-based threat detection engine will be quantitatively evaluated using a confusion matrix-based approach. The following mathematical foundations will be used to prove the success of the model:

$$\text{Accuracy} = \frac{TP + TN}{TP + TN + FP + FN} \tag{2}$$

$$F1\text{-Score} = 2 \times \frac{\text{Precision} \times \text{Recall}}{\text{Precision} + \text{Recall}} \tag{3}$$

In addition to classification accuracy, the system must meet industrial performance benchmarks for real-time traffic analysis. We target a maximum detection latency of:

$$\Delta T < 60 \text{ ms} \tag{4}$$

This ensures that the security overhead does not negatively impact user experience or service availability.

I target a Detection Latency $\Delta T < 60$ ms to meet industrial standards.

7.5 Implementation Timeline (Gantt Chart)

This research execution will begin immediately after proposal approval (starting May 4 , 2026) and will follow a 10-week lifecycle. The proposal writing phase (March 24 - May 1, 2026) has already been completed and included literature review, data collection, model design, synthesis matrix, and system architecture design.

The remaining 10 weeks will be dedicated to the implementation, training, evaluation, and documentation of the proposed CNN-LSTM hybrid model with SHAP-based XAI interpreter.

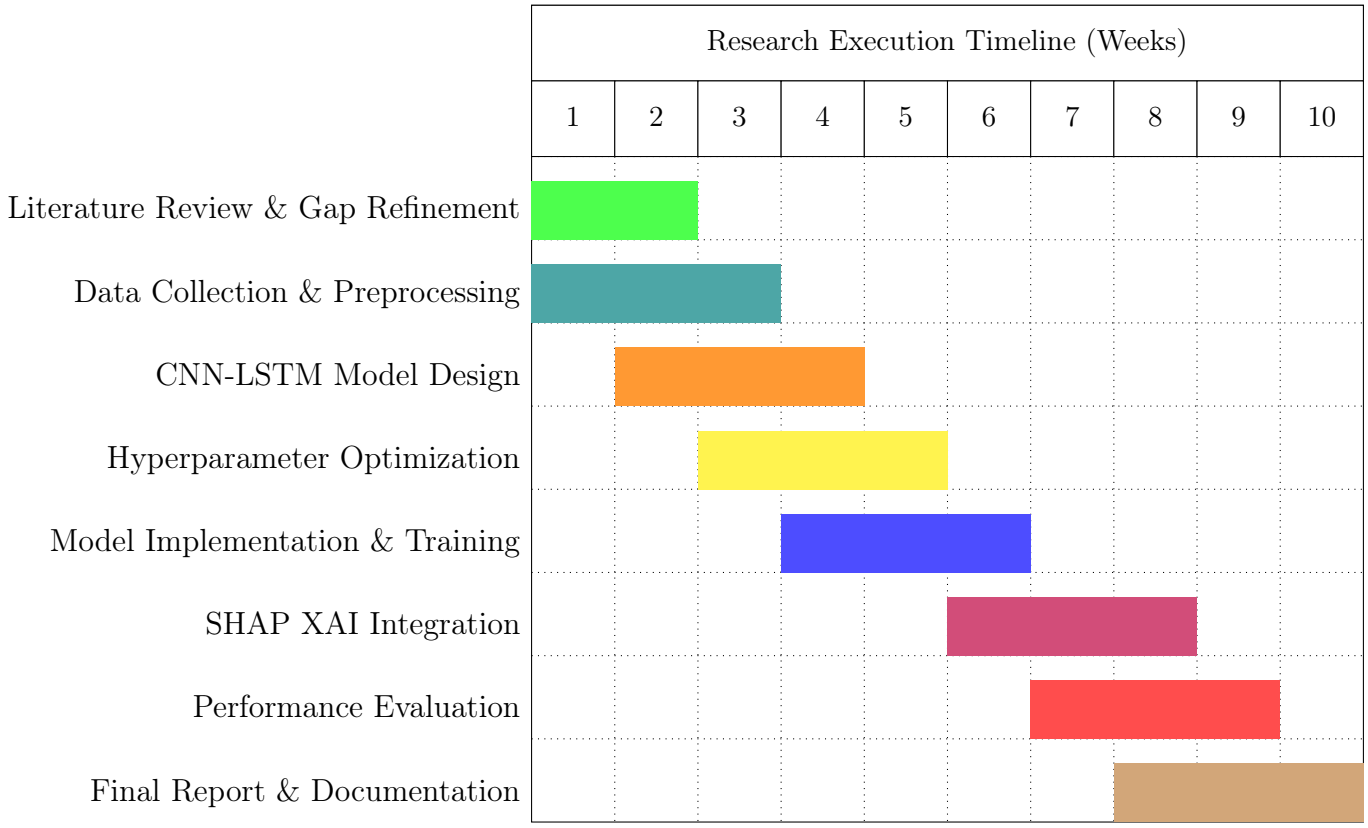

Figure 2: Research Execution Timeline (10 Weeks Post-Proposal Approval)

7.6 Ethical Considerations

This research prioritizes data privacy and responsible data handling by utilizing anonymized datasets in accordance with General Data Protection Regulation (GDPR) principles. All Personally Identifiable Information (PII) will be removed prior to analysis, and differential privacy techniques will be applied during model training to reduce the risk of data

leakage and unauthorized data reconstruction.

To ensure fairness, systematic bias audits will be conducted to detect and mitigate potential discrimination across varying traffic patterns and user behaviors. Additionally, Explainable Artificial Intelligence (XAI) techniques, specifically SHAP and LIME, will be integrated into the system to enhance transparency and improve the interpretability of model decisions.

The proposed system will be designed to maintain a balance between security and usability by reducing false positive rates, thereby preventing the unintended blocking of legitimate users. Furthermore, regular evaluation and testing will be performed to strengthen the system against adversarial attacks and potential exploitation.

Overall, the framework emphasizes privacy preservation, fairness, transparency, and robust security performance, ensuring ethical and reliable deployment in real-world web application environments.

8 Version Control

.On my research I will utilize Git for state management and GitHub for remote collaboration and documentation [15]. The primary benefits include:

- **LaTeX Management:** Keeps modular report source files organized and prevents data loss during complex document compilations.
- **Scientific Reproducibility:** Tracks atomic changes in AI model architectures, hyperparameter tuning, and training dataset versions.
- **Future Scalability:** Enables seamless branching and merging for multi-contributor development and peer code review.
- **Auditability:** Replaces manual file versioning with a cryptographically secure, searchable history of all research iterations.

9 Standard Workflow

The following commands define the standardized interaction with the project repository to maintain synchronization between local and remote environments:

Listing 1: Git Basic Commands for Research Lifecycle

```
# Initialize the local research environment
git init

# Stage changes (LaTeX source, dataset samples, or Python scripts)
git add .

# Save a snapshot with a descriptive message for the audit trail
git commit -m "Integrated hybrid CNN-LSTM architecture and
   evaluation metrics"

# Upload local changes to the GitHub repository
git push origin main

# Sync local workspace with the latest remote updates
git pull origin main
```

References

[1] Ethiack Research Team, "Waf evasion techniques: Parameter pollution and obfuscation," Ethiack Security Research, 2024. [Online]. Available: https://ethiack.com/blog/web-application-firewall-evasion-techniques-parameter-pollution

[2] IBM Security, "Cost of a data breach report 2025," IBM Corporation, Tech. Rep., 2025. [Online]. Available: https://www.ibm.com/reports/data-breach

[3] NIST National Vulnerability Database, "Cve statistics for 2025," NVD, 2025. [Online]. Available: https://nvd.nist.gov/

[4] Verizon, "Data breach investigations report (dbir) 2025," Verizon Enterprise, Tech. Rep., 2025. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[5] Google Project Zero, "Zero-day exploits: 2025 year in review," *Google Security Blog*, 2025. [Online]. Available: https://googleprojectzero.blogspot.com/

[6] S. Al and S. Sagiroglu, "Explainable artificial intelligence models in intrusion detection systems," *Engineering Applications of Artificial Intelligence*, vol. 144, p. 110145, 2025, xAI techniques (SHAP/LIME) for intrusion detection interpretation. [Online]. Available: https://doi.org/10.1016/j.engappai.2025.110145

[7] IBM Security, "Cost of a data breach report 2024," IBM Corporation, Tech. Rep., 2024. [Online]. Available: https://www.ibm.com/reports/data-breach

[8] M. Fu, C. Tantithamthavorn, T. Le, and V. Nguyen, "Codebert for vulnerability detection: Are we there yet?" in *Proceedings of the 37th IEEE/ACM International Conference on Automated Software Engineering (ASE)*, 2022, pp. 1–12, codeBERT for vulnerability detection with high accuracy but high computational cost. [Online]. Available: https://dl.acm.org/doi/10.1145/3551349.3556955

[9] A. Riverol, G. Betarte, R. Martinez, and A. Pardo, "Capturing the security expert knowledge in feature selection for web application attack detection," in *Proceedings of the Latin American Symposium on Dependable Computing (LADC)*, 2024,

mL ensemble achieving 99.3% accuracy without adversarial robustness. [Online]. Available: https://arxiv.org/abs/2407.18445

[10] G. Floris, C. Scano, B. Montaruli, L. Demetrio, A. Valenza, L. Compagna, D. Ariu, L. Piras, D. Balzarotti, and B. Biggio, "ModSec-AdvLearn: Countering adversarial sql injections with robust machine learning," *IEEE Transactions on Information Forensics and Security*, vol. 20, pp. 2456–2470, 2025, real-time ML framework with adversarial training but lacking prevention layer and XAI. [Online]. Available: https://ieeexplore.ieee.org/document/10472489

[11] N. Thalji, A. Raza, M. S. Islam, N. A. Samee, and M. M. Jamjoom, "Ae-net: Novel autoencoder-based deep features for sql injection attack detection," *IEEE Access*, vol. 11, pp. 135 507–135 516, 2023, autoencoder-based approach achieving 99% k-fold accuracy with XGBoost classifier. [Online]. Available: https://ieeexplore.ieee.org/document/10332180

[12] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "CIC-IDS2017 dataset," Canadian Institute for Cybersecurity, University of New Brunswick, 2017, network intrusion detection dataset lacking modern web-specific attack vectors. [Online]. Available: https://www.unb.ca/cic/datasets/ids-2017.html

[13] M. Sekyewa, J. Sansa-Otim, and R. Ngobiro, "Transformer-based ensemble learning for web application attack detection," *Journal of Cybersecurity and Privacy*, vol. 3, no. 2, pp. 156–172, 2023. [Online]. Available: https://www.mdpi.com/2624-800X/3/2/10

[14] T. Sureda Riera, J. R. Bermejo Higuera, J. Bermejo Higuera, J. J. Martínez-Herráiz, and J. A. Sicilia Montalvo, "A new multi-label dataset for web attacks capec classification using machine learning techniques," *Computers & Security*, vol. 120, p. 102788, 2022, introduces SR-BH 2020 multi-label dataset for CAPEC web attack classification. [Online]. Available: https://www.sciencedirect.com/science/article/pii/S0167404822001833

[15] A. Shemelis, "Research proposal paper: Enhancing web application security using ai-based threat detection systems," GitHub, 2026. [Online]. Available: https://github.com/Abayshemelis/ResearchProposalPaper